

Splunk Bots v1 攻击溯源

https://github.com/Sean-Everett/Splunk-Boss_of_the_SOC_v1/tree/main

场景一

展示了攻击组织 Po1s0n1vy 对 Wayne Enterprise 的网站 `imreallynotbatman.com` 进行攻击并最终篡改网页的完整过程。

侦察与漏洞扫描

溯源思路：攻击者在发起攻击前通常会对目标进行大规模的扫描。通过检索目标域名的全局流量，可以找出请求量异常高的源 IP，并分析 HTTP 请求头（Headers）来识别攻击者使用的工具。

使用下面的语句查询所有包含关键字 `imreallynotbatman.com` 的日志

SPL

1 index="botsv1" imreallynotbatman.com

index="botsv1" imreallynotbatman.com

✓ 78,683 个事件 (26/06/02 6:56:57.000 之前) 无事件采样 ▼

事件 (78,683) 模式 统计信息 可视化

设定时间线的格式 ▼ - 缩小 + 缩放到所选区域 × 取消选择

列表 ▼ 格式 每页 20 个 ▼

< 隐藏字段 所有字段

选定字段
a host 4
a source 4
a sourcetype 4

感兴趣的字段
ack_packets_in 41
ack_packets_out 12
a action 4
a app 3
a app_proto 1
bytes 100+
bytes_in 100+
bytes_out 100+
a c_ip 3

i 时间 事件

> 16/08/10 22:23:09.473 { [-]
app_proto: http
dest_ip: 40.80.148.42
dest_port: 49501
event_type: fileinfo
fileinfo: { [+]
}
flow_id: 3318498196
http: { [+]
}
in_iface: eth1
proto: TCP
src_ip: 192.168.250.70
src_port: 80
timestamp: 2016-08-10T16:23:09.473182-0600

统计出现次数最多的前10个源IP地址。

SPL

```
1 index="botsv1" imreallynotbatman.com | top limit=10 src_ip
```

命令提示

index="botsv1" imreallynotbatman.com | top limit=10 src_ip 所有时间

✓ 78,683 个事件 (26/06/02 6:58:34.000 之前) 无事件采样

任务 统计信息 (3) 可视化

每页 20 个 格式 预览

src_ip	count	percent
40.80.148.42	38416	72.767223
192.168.250.70	11493	21.769932
23.22.63.114	2884	5.462845

排除内网地址 192.168.250.70 后, 还存在 40.80.148.42 和 23.22.63.114。

其中 40.80.148.42 占比超过 72%, 由于流量巨大, 这个可以认为 IP 地址正在扫描我们的服务器。

通过进一步展开该 IP 对应http流的 src_headers 字段数据:

代码块

```
1 index=botsv1 imreallynotbatman.com sourcetype="stream:http"
  src_ip="40.80.148.42" | top src_headers
```

index=botsv1 imreallynotbatman.com sourcetype="stream:http" src_ip="40.80.148.42" | top src_headers

✓ 20,932 个事件 (26/06/02 7:13:22.000 之前) 无事件采样

事件 模式 统计信息 (10) 可视化

每页 20 个 格式 预览

src_headers

POST /joomla/index.php/component/search/ HTTP/1.1 Content-Length: 99 Content-Type: application/x-www-form-urlencoded Cookie: ae72c62a4936b238523950a4f26f67d0=v7ikb3m59romokqmbiet3vphv3 Host: imreallynotbatman.com Connection: Keep-alive Accept-Encoding: gzip,deflate User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21 Acunetix-Product: WVS/10.0 (Acunetix Web Vulnerability Scanner - Free Edition) Acunetix-Scanning-agreement: Third Party Scanning PROHIBITED Acunetix-User-agreement: http://www.acunetix.com/wvs/disc.htm Accept: */*
POST /joomla/index.php/component/search/ HTTP/1.1 Content-Length: 102 Content-Type: application/x-www-form-urlencoded Cookie: ae72c62a4936b238523950a4f26f67d0=v7ikb3m59romokqmbiet3vphv3 Host: imreallynotbatman.com Connection: Keep-alive Accept-Encoding: gzip,deflate User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21 Acunetix-Product: WVS/10.0 (Acunetix Web Vulnerability Scanner - Free Edition) Acunetix-Scanning-agreement: Third Party Scanning PROHIBITED Acunetix-User-agreement: http://www.acunetix.com/wvs/disc.htm Accept: */*

发现攻击者使用了名为 "Acunetix" 的 Web 漏洞扫描器。同时确认了该目标网站使用的是 Joomla 内容管理系统 (CMS)。

漏洞利用与暴力破解

溯源思路： 确定目标是 Web 服务器后，攻击者在扫描无果的情况下选择了对 Joomla 后台进行暴力破解。因为登录需要通过 POST 方法提交表单，可以通过过滤 HTTP POST 请求、目标 IP 以及表单数据字段（包含 username 和 passwd）来定位爆破行为。

SPL

1 index="botsv1" sourcetype="stream:http" http_method="POST"

dest_ip="192.168.250.70" form_data=*username*passwd*

2 | stats count by src_ip

index="botsv1" sourcetype="stream:http" http_method="POST" dest_ip="192.168.250.70" form_data=*username*passwd*

| stats count by src_ip

✓ 413 个事件 (26/06/02 7:27:25.000 之前) 无事件采样 ▼

事件 模式 统计信息 (2) 可视化

每页 20 个 ▼ 格式 预览 ▼

src_ip ↕

23.22.63.114

40.80.148.42

发现源 IP 23.22.63.114 正在对服务器发起大量爆破请求。

扩展分析（密码细节）： 通过附加 | table _time form_data | reverse 语句，发现攻击者尝试的第一个密码是 123456788。

扩展分析（爆破结果）： 通过使用正则表达式 | rex field=form_data "passwd=(?<userpassword>\w+)" | stats count by userpassword 提取密码，发现 batman 这个密码在日志中出现了两次，这暗示它是最终被成功破解的正确密码。整个过程中，攻击者共尝试了 413 个不重复的密码。

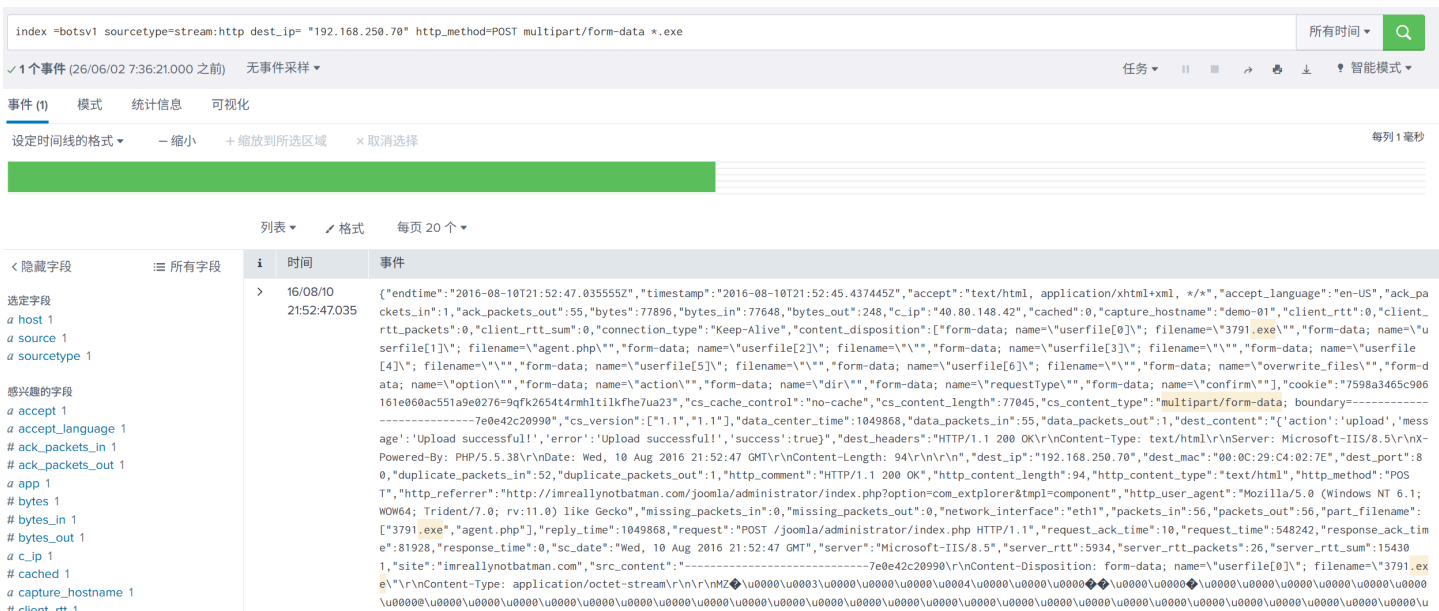
恶意载荷安装

溯源思路： 攻击者在成功爆破获取 Joomla 后台权限后，通常会利用后台的文件上传功能来植入后门或恶意程序。Web 文件上传通常使用 HTTP POST 方法，并且其 Content-Type 为 multipart/form-data。我们可以通过过滤目标服务器 IP 的 HTTP 流量、限制 POST 请求与表单类型，并直接搜索常见的可执行文件后缀（如 *.exe）来精准定位恶意文件的上传行为。

代码块

```
1 index =botstv1 sourcetype=stream:http dest_ip= "192.168.250.70"
http_method=POST multipart/form-data *.exe
```

通过执行上述包含 `multipart/form-data` 和 `*.exe` 的流量查询，排除了正常的网页访问干扰，精准定位并确认攻击者成功上传了一个名为 `3791.exe` 的可执行文件。



随后，利用获取到的文件名 `3791.exe` 进一步结合 Sysmon 日志进行检索，成功提取到了该恶意文件的 MD5 哈希值。这个哈希值为后续在威胁情报平台（如 VirusTotal）上进行拓线分析提供了最关键的指纹凭证。

```
SPL
1  index=botsv1 3791.exe md5 sourcetype="XmlWinEventLog:Microsoft-Windows-
   Sysmon/Operational" CommandLine="3791.exe"
2  | rex field="_raw" "MD5=(?<hash>\w+)"
3  | table hash
4  | stats count by hash
```

```
1 index=botsv1 3791.exe md5 sourcetype="XmlWinEventLog:Microsoft-Windows-
  Sysmon/Operational" CommandLine="3791.exe"
2 | rex field="_raw" "MD5=(?<hash>\w+)"
3 | table hash
4 | stats count by hash
```

达成目标与网页篡改

溯源思路：网站被篡改往往涉及页面内容的替换或外部媒体文件的加载。通过分析 Suricata 流量日志，检查目标 Web 服务器返回的文件内容类型（如 `image/jpeg`），可以找到被替换的网页素材。

```
SPL

1  index=botsv1 sourcetype="suricata" src_ip="192.168.250.70"
   dest_ip="23.22.63.114"
2  | stats count by http.http_method, http.hostname, http.url
3  | sort -count
```

```
1 index=botsv1 sourcetype="suricata" src_ip="192.168.250.70"
  dest_ip="23.22.63.114"
2 | stats count by http.http_method, http.hostname, http.url
3 | sort -count
```

index=botsv1 sourcetype="suricata" src_ip="192.168.250.70" dest_ip="23.22.63.114"
| stats count by http.http_method, http.hostname, http.url
| sort -count

✓ 1,294 个事件 (26/06/02 7:41:33.000 之前) 无事件采样 ▼

事件 模式 统计信息 (4) 可视化

每页 20 个 ▼ 格式 预览 ▼

http.http_method ↕	http.hostname ↕	http.url ↕
GET	imreallynotbatman.com	/joomla/administrator/index.php
POST	imreallynotbatman.com	/joomla/administrator/index.php
GET	71.39.18.126	/joomla/agent.php
GET	prankglassinebracket.jumpingcrab.com	/poisonivy-is-coming-for-you-batman.jpeg

过查看 HTTP 的 url 字段，发现了一张恶意的 JPEG 图片。该图片名为 `poisonivy-is-coming-for-you-batman.jpeg`。

进一步分析发现，这张图片托管在攻击者的动态 DNS 域名 `prankglassinebracket.jumpingcrab.com` 上，并且使用了非标准端口 `1337`。该域名直接解析到了之前发现的爆破 IP `23.22.63.114`。

```
> 16/08/10 { [-]
22:17:46.942   dest_ip: 23.22.63.114
               dest_port: 1337
               event_type: http
               flow_id: 1172520240
               http: { [-]
                   hostname: prankglassinebracket.jumpingcrab.com
                   http_method: GET
                   length: 0
                   protocol: HTTP/1.0
                   url: /poisonivy-is-coming-for-you-batman.jpeg
               }
               in_iface: eth1
               proto: TCP
               src_ip: 192.168.250.70
               src_port: 63139
               timestamp: 2016-08-10T16:17:46.942205-0600
               tx_id: 0
           }
```

显示为原始文本

场景二

感觉有点难以还原，先做场景一

[medium.com](#)

事件背景： 2016 年 8 月 24 日，员工 Bob Smith 的 Windows 10 工作站（主机名：`we8105desk`）遭到 Cerber 勒索软件感染，导致本地文件及网络共享文件被全面加密。

初始访问

核心事实：攻击并非通过钓鱼邮件发起，而是 Bob Smith 捡到了一个遗落在停车场的恶意 USB 闪存盘，将其插入办公电脑后，打开了其中的恶意 Office 宏文档 `Miranda_Tate_unveiled.dotm`

溯源线索与分析：为了确认受害主机的 IP 以及插入的 USB 设备记录，我们需要结合 Sysmon 的网络连接日志和 Windows 注册表日志。

```
SPL

1  index=botsv1 source="WinEventLog:Microsoft-Windows-Sysmon/Operational"
   host=we8105desk EventID=3
2  | top limit=5 SourceIp
```

index=botsv1 source="WinEventLog:Microsoft-Windows-Sysmon/Operational" host=we8105desk top limit=5 SourceIp	
✓ 130,353 个事件 (26/06/02 7:52:32.000 之前) 无事件采样 ▼	
事件	模式 统计信息 (5) 可视化
每页 20 个 ▼	格式 预览 ▼
SourceIp ↕	count ↕
192.168.250.100	53106
127.0.0.1	104
192.168.250.255	70
0.0.0.0	42
224.0.0.252	6

确认受害主机 `we8105desk` 在事发时的核心 IP 地址为 `192.168.250.100`。

```
SPL

1  index=botsv1 sourcetype=winregistry friendlname
```

i	时间	事件
>	16/08/24 16:42:17.000	08/24/2016 10:42:17.287 event_status="(0)The operation completed successfully." pid=708 process_image="c:\Windows\System32\svchost.exe" registry_type="SetValue" key_path="HKLM\system\controlset001\enum\wpdbsenumroot\umb\2837c186b&0&storage#volume#_??_usbstor#disk&ven_generic&prod_flash_disk&rev_8.07#7d961196&0#\friendlname" data_type="REG_SZ" data="MIRANDA_PRI" 折叠 host = we8105desk source = WinRegistry sourcetype = WinRegistry

Windows 注册表会记录 USB 的友好名称。查询发现 Bob 插入的 USB 驱动器名称为 `MIRANDA_PRI`。

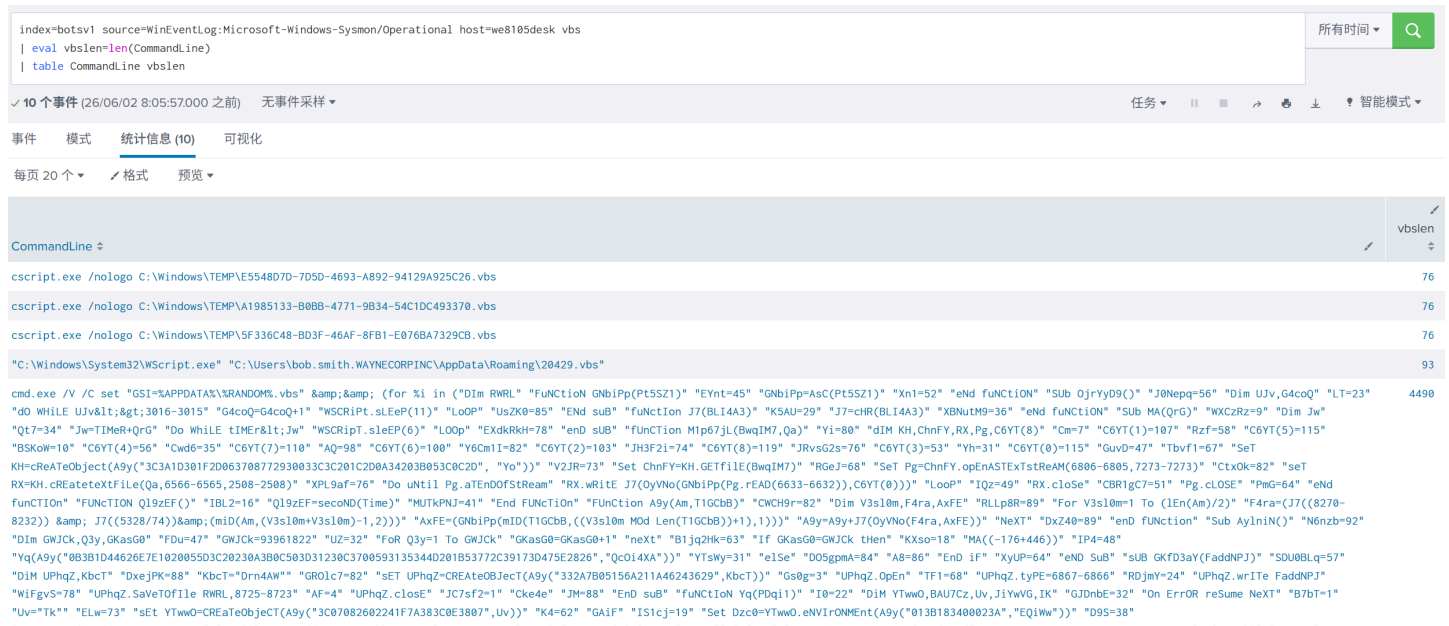
执行

核心事实：Bob 打开文档后，恶意宏在后台静默执行了一段 VBScript。该脚本随后释放并调用了一个名为 `121214.tmp` 的临时执行文件，正式启动勒索软件的核心进程。

溯源线索与分析：我们需要分析 Sysmon 的进程创建日志（EventCode=1），抓取命令行（CommandLine）中超长的混淆代码以及恶意子进程。

SPL

```
1 index=botsv1 source=WinEventLog:Microsoft-Windows-Sysmon/Operational
  host=we8105desk vbs
2 | eval vbslen=len(CommandLine)
3 | table CommandLine vbslen
```



发现一段由 `cmd.exe` 执行的极长的混淆 VBS 脚本，其命令行长度达到了 4490 个字符。

SPL

```
1 index=botsv1 host=we8105desk EventID=1 CommandLine=*121214.tmp* | table _time
ProcessId ParentProcessId
```

index=botsv1 host=we8105desk EventID=1 CommandLine=*121214.tmp* | table _time ProcessId ParentProcessId

所有时间

✓ 5 个事件 (26/06/02 8:08:49.000 之前) 无事件采样 ▾

任务 ▾ || ≡ ↶ ⚙ ⌵ ! 智能模式 ▾

事件 模式 统计信息 (5) 可视化

每页 20 个 ▾ ↗ 格式 预览 ▾

_time ↕	ProcessId ↕ 🔍	ParentProcessId ↕ 🔍
2016/08/24 16:48:29	3828	2948
2016/08/24 16:48:21	2948	1476
2016/08/24 16:48:21	1476	3968
2016/08/24 16:48:41	1684	1280
2016/08/24 16:48:41	1280	3828

日志显示，上述恶意脚本作为父进程（ID: 3968），成功拉起了初始的勒索启动文件 121214.tmp。

C2

核心事实：勒索软件在本地启动后，开始向外部恶意的 DNS 服务器发起解析请求以连接 C2 基础设施，并下载了包含 Cerber 真正加密器代码的伪装文件。网络 IDS (Suricata) 和防火墙 (Fortigate) 记录了这些异常。

代码块

```
1 index=botsv1 sourcetype=suricata cerber
2 | stats count by alert.signature_id
```

index=botsv1 sourcetype=suricata cerber
| stats count by alert.signature_id

所有时间

✓ 5 个事件 (26/06/02 8:12:42.000 之前) 无事件采样

任务 统计信息 (3) 可视化

每页 20 个 格式 预览

alert.signature_id	count
2816763	1
2816764	2
2820156	2

16/08/24 16:49:36.481

```
{ [-]
  alert: { [-]
    action: allowed
    category: A Network Trojan was detected
    gid: 1
    rev: 2
    severity: 1
    signature: ETPRO TROJAN Ransomware/Cerber Checkin Error ICMP Response
    signature_id: 2816764
  }
  dest_ip: 192.168.250.100
  event_type: alert
  flow_id: 541721016
  icmp_code: 3
  icmp_type: 3
  in_iface: eth1
  proto: ICMP
  src_ip: 85.93.43.236
  timestamp: 2016-08-24T10:49:36.481828-0600
}
```

显示为原始文本

host = suricata-ids.waynecorpinc.local | source = /var/log/suricata/eve.json | sourcetype = suricata

SPL

```
1 index=botsv1 sourcetype=stream:dns src_ip=192.168.250.100 "query_type{}"=A NOT
  (query{}=*.microsoft.com OR query{}=*.google.com OR query{}=*.waynecorpinc.com)
2 | table _time query{} src dest
```


index=botsv1 sourcetype=stream:dns src_ip=192.168.250.100 "query_type{}"="A NOT (query{}=*.microsoft.com OR query{}=*.google.com OR query{}=*.waynecorpinc.com)
| table _time query{} src dest

✓ 156 个事件 (26/06/02 8:14:44.000 之前) 无事件采样 ▼

任务 ▼

事件 模式 统计信息 (156) 可视化

每页 20 个 ▼ 格式 预览 ▼				< 上一个 1 2	
_time ↕	query[] ↕	src ↕	dest ↕		
2016/08/24 16:53:18.275	wpad wpad	192.168.250.100	22		
2016/08/24 16:53:18.275	wpad wpad	192.168.250.100	22		
2016/08/24 16:53:18.168	wpad wpad	192.168.250.100	22		
2016/08/24 16:53:18.168	wpad wpad	192.168.250.100	22		
2016/08/24 16:53:18.167	wpad.waynecorpinc.local wpad.waynecorpinc.local	192.168.250.100	19		
2016/08/24 16:49:24.308	ipinfo.io ipinfo.io	192.168.250.100	19		
2016/08/24 16:48:12.267	solidaritedeproximityte.org solidaritedeproximityte.org	192.168.250.100	19		
2016/08/24 16:34:39.352	dns.msftncsi.com dns.msftncsi.com	192.168.250.100	19		

除了微软、谷歌和公司内网的白名单域名后，发现受害机访问了首个可疑域名
solidaritedeproximityte.org。